

Documentation-Driven Threat Analysis

Documentation and Base Analysis Authoring Guide

Revision 2 – documentation method

Guida operativa dalla problem framing al handoff verso Base Analysis

Stato. R24 DRAFT FOR REVIEW. La guida e' derivata dal checkpoint documentale R24 e conserva esplicitamente la distinzione fra regole CLOSED, refinement R24 WORKING e questioni OPEN/DEFERRED.

Repository baseline di riferimento. 7aeb3a1e0373357fa31c35110d9160de3e2e7d79.

Esempio ricorrente. Il caso Facial Access viene usato come esempio didattico. Gli artifact R1 sono SUPERSEDED e servono solo come regression evidence; il candidate R2 e' EXPERIMENTAL_NON_CANONICAL e non costituisce ancora una baseline governata per una BA accettata.

Indice

1	Come usare questa guida	1
1.1	Prima nozione: che cosa significano L1, L2, L3 e L4	1
1.2	Legenda epistemica	3
2	Regole trasversali prima dei singoli documenti	4
2.1	Recency non e' authority	4
2.2	Documentation authority e analysis feedback	4
3	Step 1 – Project problem framing	4
3.1	Checklist	5
4	Step 2 – MacroRequirement	5
4.1	Corpo minimo	5
4.2	Review questions	5
4.3	Esempio reale: MR-0003 prima e dopo la semantic review	6
4.4	Macro Project Map / isolated-MR review	6
5	Step 3 – Semantic-sufficiency gate	7
5.1	Dimensioni di osservazione	7
5.2	Procedura minima	7
5.3	Esempio MR-0003 – una frase plausibile, due responsabilita' diverse	8
5.4	Esempio MR-0003 – wording migliore, ma ancora non sufficiente	8
5.5	Esempio MR-0003 – estrarre la smallest critical proposition	8
5.6	Esempio MR-0003 – neutral labels per disinnescare il titolo	9
5.7	Esempio MR-0003 – correzione minima sufficiente	9
5.8	Perche' la differenza diventa visibile anche downstream	10
5.9	Regola di arresto	10
6	Step 4 – Decision	11
6.1	Corpo minimo	11
6.2	Ownership test	11
7	Step 5 – FunctionalRequirement	12
7.1	Review checklist	12
7.2	Allowed domain vs decision rule	13
8	Step 6 – Common Requirement coherent-unit / split	13
9	Step 7 – SpecializedRequirement	14
10	Step 8 – SecurityRequirement	15

11 Step 9 – Cross-MR e consumed-service boundary	15
11.1 Consumption vs ownership	15
11.2 Required property vs governed service guarantee	16
12 Step 10 – Canonical terminology e review bindings	17
12.1 Temporary review markers	17
13 Step 11 – Downstream semantic propagation	17
13.1 Facial Access propagation example	18
14 Step 12 – Documentation completeness e promotion gate	18
15 Step 13 – Handoff a Base Analysis	19
16 Step 14 – BA / analysis feedback senza authority inversion	19
17 Checklist compatta documento per documento	19
18 Known open items – non chiudere per comodita’	20
19 Evidence map e status degli esempi	20
20 Final acceptance rule for this guide	21

1 Come usare questa guida

Questa guida non sostituisce la documentazione di progetto con un metamodel pesante. Il principio operativo e':

Principio – minimum sufficient governed meaning

Documentare al livello corrente la minima conoscenza governata sufficiente a rendere stabile il significato, verificabile la responsabilita' e possibile una successiva normalizzazione in Base Analysis senza inventare dettagli.

1.1 Prima nozione: che cosa significano L1, L2, L3 e L4

In alcuni punti la guida usa espressioni come “classe L1”, “campo L1” o “document-layer/L1”. Queste sigle appartengono alla terminologia interna DDTA e non possono essere date per note al lettore.

Layering DDTA – terminologia da conoscere prima di proseguire

I livelli L1–L4 separano *chi possiede il significato* da *come quel significato viene scritto, validato o supportato da un tool*. Non sono quattro fasi di authoring e non sono quattro livelli della gerarchia MR → Decision → Requirement.

Livello	Che cosa descrive	Esempio DDTA
L1	Conceptual metamodel: i concetti della metodologia, il loro significato, relazioni, cardinalita' e invarianti.	MacroRequirement, Decision, FunctionalRequirement; “ogni FR ha esattamente una parent Decision”; <code>SecurityRequirement.protectedSecurityProperty [1]</code> .
L2	Canonical representation contract: come un'istanza L1 viene materializzata in una rappresentazione governata.	Heading Markdown, ordine dei campi, encoding di un valore assente, mapping YAML/Markdown/LaTeX.
L3	Model realization principles: come software e automazione consumano L1+L2 senza diventare autorita' semantica parallela.	Validator, schema eseguibile, editor assistito, indice derivato, controllo automatico di cardinalita'.
L4	Tool support / conformance mapping: quali contratti DDTA un prodotto o tool supporta, valida, proietta o assiste.	Un tool come ThreatForge dichiara che supporta l'authoring di Decision o valida una parte strutturale del contratto FR.

La distinzione piu' importante per questa guida e':

L1 dice CHE COSA significa un concetto DDTA.
 L2 dice COME lo scriviamo in una rappresentazione canonica.
 L3 dice COME software/automazione lo consuma.
 L4 dice QUALE supporto fornisce uno specifico tool.

Telecamera – dal concetto all’istanza

```
L1 concept:
  MacroRequirement

project instance:
  MR-0003 -- Determinazione dell'identita' al punto di accesso

L2 representation:
  un documento con Title / Intent / Context / Stakeholders / Scope
  secondo il profilo di rappresentazione adottato

L3 realization:
  un validator puo' controllare che il parentage o i campi dichiarati
  rispettino il contratto, ma non decide il significato di MR-0003

L4 tool support:
  un tool puo' dichiarare di supportare authoring/review/validation
  di MacroRequirement senza diventare proprietario della semantica DDTA
```

DA EVITARE – confondere metamodel e documento

```
"MR-0003 e' una classe L1."
```

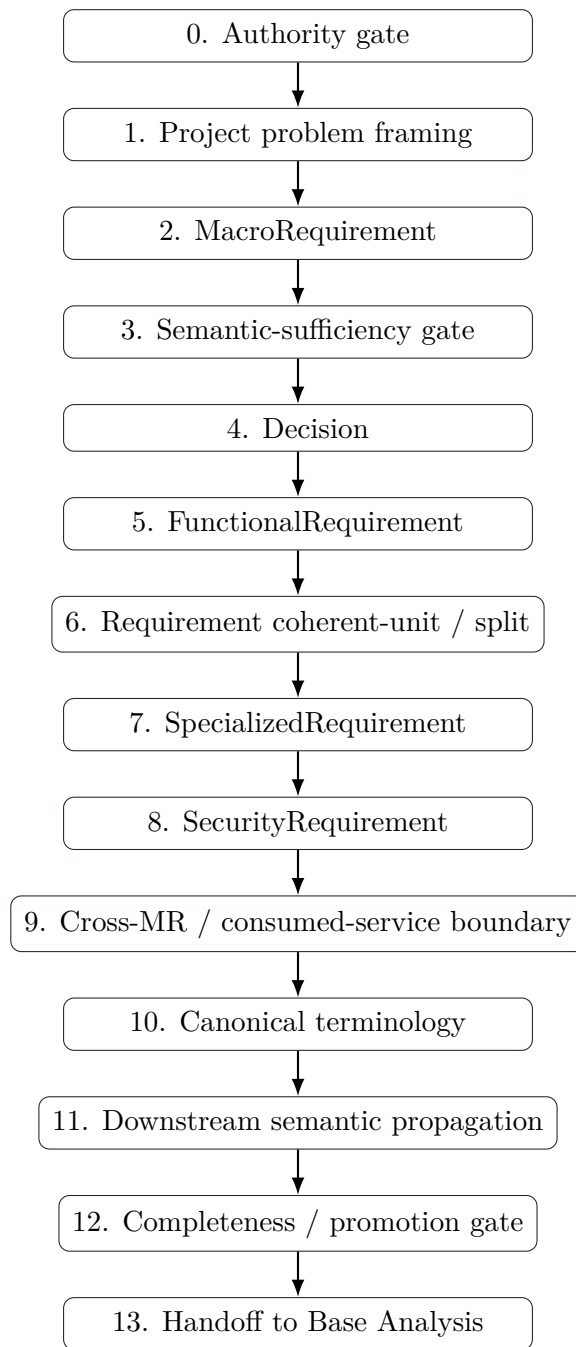
MR-0003 e' una *istanza di progetto* del concetto L1 MacroRequirement; il file Markdown/LaTeX che la materializza appartiene alla rappresentazione, non ridefinisce da solo il concetto.

CORRETTO – leggere una frase come “non creare una nuova classe L1”

Significa: non introdurre un nuovo *tipo concettuale DDTA* soltanto perche' una particolare rappresentazione, un esempio o un tool avrebbe convenienza ad averlo. Prima deve esistere una necessita' semantica metodologia-neutral.

La terminologia di layering e' una convenzione fondazionale DDTA usata per evitare authority drift. Quando questa guida parla semplicemente di “documento”, “MR”, “Decision”, “FR” o “SR”, il lettore non deve tradurre ogni frase in termini di L1–L4: i livelli vengono richiamati solo quando serve chiarire *dove vive una responsabilita' semantica*.

La sequenza di lavoro e':



Non ogni step crea un nuovo tipo di documento. Alcuni sono gate o review step. In particolare semantic sufficiency, Macro Project Map review, downstream regression e service-guarantee review sono discipline di controllo, non nuove classi L1.

1.2 Legenda epistemica

Etichetta	Significato
CLOSED	Regola già chiusa nel proprio scope e portata avanti nel baseline corrente.
R24 WORKING	Refinement supportato da pressure test ma non ancora generalizzato come closure universale.

Etichetta	Significato
OPEN / DEFERRED	Questione preservata esplicitamente; non deve essere chiusa per comodità narrativa o di tooling.

2 Regole trasversali prima dei singoli documenti

2.1 Recency non e' authority

CLOSED

Prima di usare un artifact chiedere sempre quale baseline e quale source set sono autorizzati per l'operazione corrente. Un file piu' nuovo non diventa governato per cronologia.

DA EVITARE

"Questo file e' il piu' recente, quindi e' il requisito corrente."

CORRETTO / PREFERIBILE

"Questo artifact e' candidate / working evidence.
La baseline governata si determina tramite il registry di authority."

2.2 Documentation authority e analysis feedback

La direzione di authority e':

```
governed documentation
  -> Base Analysis
  -> downstream analysis / diagnostic
  -> correction candidate
  -> governed review
  -> updated documentation
  -> rebuilt Base Analysis
```

Una BA o un'analisi possono esporre un problema, ma non possono riparare silenziosamente il significato del progetto.

3 Step 1 – Project problem framing

CLOSED

Domanda fondamentale: se rimuoviamo le scelte di soluzione correnti, quale problema generale o classe di problemi deve affrontare il progetto, e che cosa e' dentro o fuori dal boundary?

La problem framing e' una preconditione di metodo, non un ulteriore document type L1.

3.1 Checklist

- eliminare provider, device, database, framework, algoritmo e protocollo quando non sono intrinseci al problema;
- dichiarare le responsabilita' importanti fuori scope;
- usare il framing per verificare copertura e overlap degli MR;
- non duplicare meccanicamente lo stesso framing in ogni MR.

DA EVITARE – framing gia' soluzione

`Il progetto deve usare una telecamera IP Ethernet e un PC locale per riconoscere il volto e aprire il tornello.`

Problema: camera, Ethernet, PC e apertura del tornello sono gia' scelte o realizzazioni. Il framing non lascia visibile il problema indipendentemente dalla soluzione.

PREFERIBILE – framing del problema

`Il progetto deve controllare l'accesso a un'area riservata, distinguendo la persona presente, il relativo stato di autorizzazione e la decisione sul singolo tentativo di accesso.`

La formulazione sopravvive alla sostituzione della camera, del riconoscimento facciale, della rete o del meccanismo fisico di apertura.

4 Step 2 – MacroRequirement

CLOSED

Domanda fondamentale: nel problema gia' inquadrato, quale responsabilita' macro stabile stiamo governando, quale risultato o valore macro contribuisce, perche' conta e chi coinvolge?

4.1 Corpo minimo

Title
Intent
Context
Stakeholders
Scope
Assumptions/Constraints [solo se branch-wide]
dependsOn MR [quando genuino]

4.2 Review questions

- esiste una sola macro-responsabilita' coerente?
- resta significativa cambiando tecnologia/architettura?
- contiene gia' un comportamento atomico da FR?
- contiene gia' una scelta di soluzione da Decision?

- una dependency e' confusa con containment?
- Intent + Context + Scope determinano un solo significato stabile?

4.3 Esempio reale: MR-0003 prima e dopo la semantic review

Il superseded R1 recitava, in sintesi:

REGRESSION EVIDENCE – formulazione R1

MR-0003 -- Verifica dell'identita' al punto di accesso

Intent:

stabilire se la persona presente corrisponde a un'identita' governata.

Questa formulazione ammetteva due letture materialmente diverse:

- A. l'identita' specifica non e' ancora nota;
la responsabilita' determina QUALE GovernedIdentity corrisponde.
- B. una GovernedIdentity specifica e' gia' selezionata;
la responsabilita' determina SE la persona corrisponde a quella identita'.

Non era quindi “sbagliata” in senso sintattico: era semanticamente insufficiente per distinguere due responsabilita' diverse.

CANDIDATE R2 – responsabilita' resa stabile

MR-0003 -- Determinazione dell'identita' al punto di accesso

Quando questa responsabilita' inizia, la persona e' presente
ma la specifica identita' governata che le corrisponde
non e' ancora determinata.

La responsabilita' determina quale identita' governata
corrisponde alla persona presente.

DA EVITARE – MR che assorbe la realizzazione

MR-0003 -- Riconoscimento facciale tramite CameraSubsystem
su Ethernet verso RecognitionProcessor.

Qui strategia, placement e comunicazione sono anticipati nel MacroRequirement. La sostituzione del mezzo o del componente costringerebbe a riscrivere una responsabilita' che dovrebbe restare stabile.

4.4 Macro Project Map / isolated-MR review

R24 / S1 CANDIDATE HEURISTIC

Un MR isolato non e' invalido. Un nodo isolato attiva review, soprattutto quando il contenuto sembra una raccolta di proprieta' trasversali su comportamenti posseduti da altri branch.

Domande:

1. Rimuovendo l'MR scompare una vera macro-capability/responsabilita'?
2. Oppure restano le capability e scompaiono principalmente proprieta' specializzate?
3. I discendenti plausibili sarebbero soprattutto security/privacy/performance/compliance requirements su FR altrui?
4. Manca una vera relazione `dependsOn`?
5. L'MR e' stato creato solo per dare una "casa" a una metodologia o concern category?

5 Step 3 – Semantic-sufficiency gate

R24 WORKING

Questo step e' un refinement R24 sotto pressure test. Le dimensioni A–F sono dimensioni di osservazione, non campi obbligatori del metamodel. Il caso MR-0003 e' il primo esempio reale in cui il gate ha trovato una differenza semantica materiale.

Trigger question:

Ignorando titolo e nomi suggestivi, il testo governato determina una sola responsabilita'/commitment/obligation stabile, oppure possono sopravvivere letture materialmente diverse?

Il gate non chiede se il testo potrebbe essere piu' dettagliato. Chiede se, con il dettaglio che il progetto *ha gia' deciso*, due reviewer competenti possono ancora ricostruire responsabilita' materialmente diverse.

5.1 Dimensioni di osservazione

A	context / boundary
B	participants / domains / relations
C	initial / known / observable state
D	events / activities / state transitions
E	required effect / outcome / responsibility
F	domain properties / constraints

Le dimensioni servono come lente diagnostica. Non devono trasformarsi in una checklist da riempire meccanicamente in ogni documento.

5.2 Procedura minima

1. ricostruire il significato usando neutral labels quando utile;
2. formare le piu' piccole letture materialmente diverse;
3. individuare la proposizione minima che le separa;
4. chiedere se la differenza cambia responsabilita', relazione, stato, outcome o downstream structure;
5. cercare evidenza governata;
6. classificare la proposizione come **AFFIRMED**, **DENIED**, **NOT SPECIFIED** o **CONFLICTING**;
7. correggere il livello che possiede semanticamente il significato;

8. fermarsi quando la distinzione materiale e' stabilizzata: semantic sufficiency non significa semantic exhaustiveness.

5.3 Esempio MR-0003 – una frase plausibile, due responsabilita' diverse

Il precedente MR-0003 governato diceva, in sostanza:

FORMULAZIONE R1 – semanticamente ambigua

Consentire al processo di accesso di stabilire se la persona presente al punto di accesso corrisponde a un'identita' governata.

La frase e' leggibile, ma lascia sopravvivere due ricostruzioni diverse:

Lettura A – identita' non ancora determinata

persona presente
-> responsabilita'
-> determinare QUALE
 identita' governata corrisponde

Lettura B – identita' gia' selezionata

persona presente
+ specifica identita' governata
-> responsabilita'
-> determinare SE corrispondono

La differenza non e' lessicale. Cambia lo **stato all'ingresso** e cambia il ruolo della specifica identita': nella lettura A e' un risultato della responsabilita'; nella lettura B e' gia' disponibile come riferimento/input.

Materiality test

Se due letture producono partecipanti, precondizioni, input/result, responsabilita' o outcome diversi, la differenza e' materialmente rilevante anche se entrambe le frasi “suonano ragionevoli” in linguaggio naturale.

5.4 Esempio MR-0003 – wording migliore, ma ancora non sufficiente

Durante il lavoro R24 era stata usata una formulazione piu' forte:

MIGLIORE, MA ANCORA SOTTILE

stabilire a quale GovernatedIdentity corrisponde PersonAtAccessPoint

Questa formulazione orienta verso la lettura A, ma il finding ha mostrato che affidarsi soltanto alla differenza linguistica fra “a quale” e “se ... corrisponde” e' fragile. Il fatto di entry-state che separa A e B non era ancora dichiarato esplicitamente.

Questa e' una lezione importante per la semantic sufficiency:

better wording != sufficiently stabilized meaning

5.5 Esempio MR-0003 – estrarre la smallest critical proposition

La proposizione minima che separava A e B era:

CRITICAL PROPOSITION

Una specifica GovernedIdentity e' gia' disponibile/selezionata come riferimento prima che inizi la responsabilita'.

Prima della clarification di progetto, la classificazione corretta era:

AFFIRMED	no
DENIED	no
CONFLICTING	no
NOT SPECIFIED	yes

DA EVITARE – inference che chiude il gap

"Si chiama verifica, quindi certamente esiste gia' un'identita' specifica da verificare."

Titolo, pattern, esperienza di dominio o LLM possono suggerire una lettura, non diventano project authority.

CORRETTO – preservare il NOT SPECIFIED

Evidence: NOT SPECIFIED

Action:

formulare la discriminator question;
chiedere evidenza/clarification al semantic owner;
non scegliere A o B nella BA o nel downstream.

La clarification di progetto ha poi stabilito:

specific GovernedIdentity already selected at entry	-> DENIED
responsibility determines which GovernedIdentity	-> AFFIRMED

5.6 Esempio MR-0003 – neutral labels per disinnescare il titolo

Quando il nome “verifica” rischia di guidare la risposta, si puo' temporaneamente rimuovere il lessico suggestivo:

NEUTRAL-LABEL REVIEW

```
#<PERSON_PRESENT>      available at entry
#<SPECIFIC_IDENTITY>    not yet determined at entry

*<RESPONSIBILITY_A>
  determines which #<SPECIFIC_IDENTITY>
  corresponds to #<PERSON_PRESENT>
```

I marker sono strumenti temporanei di review. Una volta stabilizzato il significato, il documento finale torna a prosa umana fluida.

5.7 Esempio MR-0003 – correzione minima sufficiente

Il candidate R2 rende esplicito proprio il fatto mancante:

CORRETTO – rendere esplicito il solo fatto discriminante

Quando questa responsabilit  inizia, la persona   presente al punto di accesso ma la specifica identita' governata che le corrisponde non   ancora determinata.

Questa aggiunta stabilizza l'entry state senza decidere prematuramente come la determinazione verrebbe realizzata.

DA EVITARE – trasformare semantic sufficiency in completezza tecnica

La camera acquisisce il volto, il modello calcola uno score, applica una threshold e sceglie il candidato top-1.

Questi dettagli possono essere realistici, ma non sono necessari per chiudere la differenza A/B e non sono governati dal MR-0003 candidate corrente. Aggiungerli qui sarebbe over-modeling, non semantic sufficiency.

5.8 Perche' la differenza diventa visibile anche downstream

La stessa ambiguit  puo' produrre strutture analitiche diverse:

A – identita' determinata dalla responsabilit 

```
input  -> PERSON
result -> IDENTITY
result -> EVIDENCE
```

B – identita' gia' input

```
input  -> PERSON
input  -> IDENTITY
result -> EVIDENCE
```

Questo non autorizza a usare la BA per scegliere il significato. Mostra perche' una piccola ambiguit  documentale puo' diventare materialmente rilevante: se il progetto non chiude il fatto, la derivazione downstream deve fermarsi o registrare l'incertezza.

5.9 Regola di arresto

Il reviewer non deve continuare ad aggiungere dettagli dopo avere chiuso la distinzione materiale:

1. esiste una differenza materiale?
 NO -> stop, non espandere per completezza
 YES -> trova la smallest critical proposition
2. il progetto la governa?
 YES -> preserva quel significato
 NO -> NOT SPECIFIED / CONFLICTING e ritorno al semantic owner
3. la distinzione   ora stabile?
 YES -> stop

Il caso MR-0003 non ha richiesto confidence, score, threshold, terminologia 1:N, nuovi BAReferent, nuovi operatori BA o un nuovo requisito. Questa   precisamente la differenza fra **semantica sufficiente** e **semantica esaustiva**.

6 Step 4 – Decision

CLOSED CORE / FORWARD WORDING REFINED

Domanda fondamentale: quale *material project commitment* restringe questo MR, perché il progetto assume questa posizione e quali conseguenze materiali seguono?

Usare *material project commitment* evita l'equivoco che ogni Decision debba rappresentare una libera scelta fra molte alternative. Il commitment può essere **SELECTABLE**, **NECESSITY-CONSTRAINED** o **DEFAULT**, ma non può essere un wrapper vuoto.

6.1 Corpo minimo

Title
Context
Decision
Consequences

6.2 Ownership test

Per ogni Decision chiedere anche:

Questa proposizione è una scelta/necessità adottata per realizzare questo MR, oppure descrive semplicemente una proprietà di qualcosa che il branch consuma?

CORRETTO – Decision direttamente pertinente a MR-0003

D-3.1 -- Strategia di determinazione dell'identità
mediante riconoscimento facciale

Decision:

Il progetto usa riconoscimento facciale come strategia
per determinare quale identità governata corrisponde
alla persona presente.

La Decision restringe direttamente la realizzazione di MR-0003 senza cambiare la responsabilità macro.

DA EVITARE – proprietà infrastrutturale presentata automaticamente come Decision del MR

D-3.x -- La rete è Ethernet cablata.

Se "Ethernet cablata" è solo una proprietà del servizio di comunicazione disponibile e potrebbe servire anche altri branch, non è automaticamente una Decision posseduta da MR-0003. Serve prima il test di ownership/placement.

DA EVITARE – implementation detail anticipato

D-3.1 -- Usare il modello FaceNet vX, soglia 0.83,
telecamera modello Y e TLS 1.3.

La Decision miscela strategia, algoritmo, threshold, dispositivo e protezione del trasporto.

Questi commitment possono avere ownership e lifecycle differenti.

7 Step 5 – FunctionalRequirement

CLOSED

Domanda fondamentale: data la Decision parent e gli input/condizioni applicabili, che cosa MUST fare il subject/capability, su quale significato governato, e quale risultato osservabile o failure behavior MUST seguire?

7.1 Review checklist

- comportamento operativo;
- independently assessable;
- esattamente una parent Decision;
- parent Decision pertinente;
- non ripetere la Decision;
- una sola unita' funzionale coerente;
- separare comportamenti indipendentemente modificabili;
- implementation independence;
- riuso delle identita'/riferimenti governati;
- testability senza inventare significato.

CANDIDATE R2 – FR-3.2.1

Quando viene eseguita la determinazione dell'identita', la capability di riconoscimento MUST produrre un esito governato e MUST mantenere distinguibili almeno:

- determinazione riuscita;
- determinazione negativa;
- esito non conclusivo.

Quando la determinazione riesce, MUST rendere disponibile la specifica identita' governata determinata come corrispondente.

La clausola governa il comportamento e il risultato, senza decidere authorization/access e senza imporre il meccanismo interno.

DA EVITARE – realism non governato

Il RecognitionProcessor MUST identificare la persona quando confidence > 0.82 e MUST usare top-1 matching 1:N.

Nel baseline corrente confidence, score, threshold, ranking e semantica 1:N non sono governati. Introdurli per “realismo” rende la documentazione meno stabile e inventa project meaning.

DA EVITARE – FR che invade authorization/access decision

Se il volto viene riconosciuto, il sistema **MUST** autorizzare l'accesso e aprire il varco.

Il riconoscimento determina l'identità; autorizzazione e decisione del singolo tentativo appartengono ad altre responsabilità.

7.2 Allowed domain vs decision rule**CORRETTO / PREFERIBILE**

Outcome **MUST** be one of:
 SUCCESS
 NEGATIVE
 INCONCLUSIVE

Questo governa un dominio di risultati.

DA EVITARE

```
IF score >= 0.82 THEN SUCCESS
ELSE IF score < 0.40 THEN NEGATIVE
ELSE INCONCLUSIVE
```

Se soglie e mapping non sono governati, questa apparente testabilità è semantic invention.

8 Step 6 – Common Requirement coherent-unit / split**S1.5-A CLOSED**

Un Requirement è esso stesso una obbligazione normativa governata e possiede una o più normative clauses.

```
Requirement [abstract]
  extends GovernedDocument
  normativeClause : NormativeClause [1..*]
```

Regola:

```
1 Requirement != 1 sentence
1 Requirement = 1 coherent normative obligation
```

Split test: una parte può essere introdotta, modificata, ritirata o valutata indipendentemente senza cambiare l'identità normativa delle altre? Se sì, valutare Requirement separati.

DA EVITARE – generic secure requirement

RecognitionCapture **MUST** be secure, confidential, integrity-protected and from an authorized source.

Confidentiality, integrity e authorized provenance possono evolvere ed essere valutate indipendentemente. Un unico requisito rende difficile ownership, change e verifica.

PREFERIBILE – split per obbligazioni indipendenti

```
SEC-C Confidentiality
SEC-I Integrity
SEC-P Authorized provenance
```

Ogni SecurityRequirement conserva una sola obbligazione coerente e una singola protected security property.

9 Step 7 – SpecializedRequirement**S1 CLOSED + S1.5 COMMON ABSTRACTION**

Domanda fondamentale: quale obbligazione concern-specific aggiuntiva deve valere insieme al parent FR perche' la funzione sia considerata soddisfatta, senza ridefinire la funzione ne' scegliere come realizzarla?

Checks:

- esattamente un parent FR;
- strengthening, non replacement;
- removal test: tolto lo SR, la funzione ordinaria resta riconoscibile;
- ordinary functional correctness non duplicata;
- obbligazioni indipendenti separate;
- subordinate positive behavior puo' esistere, ma resta subordinato al concern;
- nessun control/mechanism obbligato senza Decision pertinente.

CORRETTO / PREFERIBILE

```
Parent FR:
CameraSubsystem MUST deliver RecognitionCapture
al RecognitionProcessor corretto.
```

```
Specialized obligation:
Durante tale delivery, una capture modificata senza autorizzazione
MUST NOT poter essere accettata come valida.
```

Il secondo requisito restringe la soddisfazione del delivery ma non ridefinisce la funzione di delivery.

DA EVITARE

```
SpecializedRequirement:
CameraSubsystem MUST deliver RecognitionCapture.
```

Questa clausola duplica la correttezza funzionale del parent FR invece di specializzarla.

10 Step 8 – SecurityRequirement

S2 CLOSED

Un SecurityRequirement e' uno SpecializedRequirement che preserva una singola proprieta' di sicurezza governata rilevante per il parent FR e rende identificabile nelle normative clauses il failure mode che ne costituisce perdita/violazione.

```
SecurityRequirement
  extends SpecializedRequirement
  protectedSecurityProperty : SecurityProperty [1]
```

CONFIDENTIALITY – forma mechanism-neutral

Durante il delivery di RecognitionCapture,
il contenuto biometrico MUST NOT diventare intelligibile
a soggetti non autorizzati prima della sua accettazione
da parte del RecognitionProcessor.

Failure mode: il contenuto diventa intelligibile a un soggetto non autorizzato durante il comportamento protetto.

DA EVITARE – control scambiato per requirement

RecognitionCapture MUST essere protetta con TLS 1.3 e mTLS.

TLS/mTLS sono possibili scelte di realization. Il SecurityRequirement deve prima dire quale proprieta' va preservata e quale failure mode e' inaccettabile.

DA EVITARE – causa scambiata per requisito

Il sistema MUST impedire gli attacchi man-in-the-middle.

Un attacco e' una possibile causa. Il requisito deve governare l'obbligazione sul comportamento/proprieta' del parent FR; la tecnica di analysis puo' poi collegare cause e failure mode.

11 Step 9 – Cross-MR e consumed-service boundary

11.1 Consumption vs ownership

CLOSED

Una branch puo' consumare una capability/servizio senza acquisirne ownership, senza un secondo parent e senza importare automaticamente la realizzazione interna del servizio.

```
consumer branch
  -> consumes Service S

consumption != ownership
consumption != second parent
shared service != shared FR ownership
```

Camera -> RecognitionProcessor

La separazione fra acquisizione in `CameraSubsystem` e riconoscimento in `RecognitionProcessor` crea la necessita' di rendere disponibile `RecognitionCapture` al processor. Questa interazione puo' consumare un servizio di comunicazione senza trasformare MR-0003 nel proprietario dell'infrastruttura di rete.

DA EVITARE – importare la rete nel MR

MR-0003 deve fornire Ethernet, switch, VLAN e routing per il trasferimento della capture.

Se la comunicazione e' una capability consumata, il consumer non possiede automaticamente questi dettagli.

11.2 Required property vs governed service guarantee**R24 WORKING INTEGRATION CANDIDATE**

Quando il consumer fa affidamento su una proprieta' P del servizio, confrontare la proprieta' richiesta con le sole garanzie governate del servizio. L'assenza di una garanzia non genera automaticamente un requisito o un meccanismo.

```
consumer requires property P
|
v
does governed service evidence guarantee P?
|
+-- AFFIRMED
|   -> consumer may rely on the governed guarantee
|
'-- DENIED / NOT SPECIFIED / CONFLICTING
    -> coverage / assurance question remains
    -> determine semantic owner
    -> only then create/change an artifact if justified
```

CORRETTO – informazione minima oggi

MR-0003 realization consumes `CommunicationService` for `RecognitionCapture` delivery.

Service confidentiality guarantee: NOT SPECIFIED.

Questo consente di rimandare i dettagli di rete senza assumere proprieta' inesistenti.

DA EVITARE – inferenza automatica

`CommunicationService` confidentiality = NOT SPECIFIED
therefore
MR-0003 MUST use TLS.

Il passaggio e' illegittimo: NOT SPECIFIED non significa "assenza", e anche un coverage gap richiede prima ownership/placement review.

Regola pratica

Non scrivere “il canale e’ sicuro”. Scrivere, quando serve, quali proprieta’ il consumer richiede e quali proprieta’ il servizio governa come garantite. La stessa communication capability puo’ servire Camera->PC e PC->turnstile con requisiti diversi sui due flussi.

12 Step 10 – Canonical terminology e review bindings**BA5 DISCIPLINE / AUTHORING APPLICATION**

La prosa puo’ restare naturale; i binding semanticamente operativi devono usare identita’ e termini governati stabili. Grammatical variation e’ ammessa, uncontrolled synonymy no.

CORRETTO / PREFERIBILE

GovernedIdentity
 GovernedIdentity determinata
 alla GovernedIdentity corrispondente

Le flessioni grammaticali cambiano la superficie, non la semantic identity.

DA EVITARE

GovernedIdentity
 AuthorizedPerson
 KnownUser
 RecognizedProfile

Se questi termini indicano lo stesso significato senza una regola governata, introducono synonym drift e rendono piu’ difficile capire se esistano concetti diversi.

12.1 Temporary review markers

Durante review possono essere usati marker come:

```
*<RESPONSIBILITY_A>
#<GOVERNED_IDENTITY>
@<produce>
```

Devono restare visibili finche’ servono alla review e devono essere rimossi nella prosa finale di progetto.

13 Step 11 – Downstream semantic propagation**R24 WORKING – ONE REAL DOWNSTREAM CASE**

Una correzione upstream richiede review dei discendenti non solo per contraddizione diretta, ma anche per perdita di una distinzione governata, precondizioni silenziose o ownership mal posizionata.

13.1 Facial Access propagation example

Dopo la correzione di MR-0003, il downstream corretto deve preservare:

```
entry:
  person present
  specific GovernedIdentity not yet determined

responsibility:
  determine which GovernedIdentity corresponds

success outcome:
  make that specific GovernedIdentity available
```

D-3.2 / FR-3.2.1 – distinction preserved

La Decision e l'FR candidate R2 dicono esplicitamente che il riconoscimento rende disponibile la specifica identità determinata e non decide autorizzazione o accesso.

DA EVITARE – child non contraddittorio ma lossy

```
Recognition MUST compare the person with GovernedIdentity
and output positive/negative.
```

La frase può non contraddire esplicitamente MR-0003, ma reintroduce la possibilità che una specifica identità sia già input alla responsabilità.

Quando possibile, ri usare la *smallest critical proposition* come downstream regression question.

14 Step 12 – Documentation completeness e promotion gate

ACTIVE GOVERNANCE DISCIPLINE

Una candidate baseline non diventa primary BA source perché appare coerente o più recente. Serve una promozione esplicita dopo la composizione e review del successore completo.

Prima della promozione chiedere:

- tutti i branch richiesti sono assemblati coerentemente?
- le correzioni upstream sono state propagate/reviewed?
- i NOT SPECIFIED noti restano intenzionalmente aperti?
- i documenti finali sono privi di marker temporanei e research commentary?
- l'autorità registry riflette il nuovo stato?

DA EVITARE

```
"Il candidate R2 e' scritto meglio, quindi lo usiamo per la BA corrente."
```

Una candidate non è current authority senza promotion.

15 Step 13 – Handoff a Base Analysis

CLOSED

Documentation remains project authority. Base Analysis normalizza solo il significato già governato e non anticipa il dettaglio che il progetto ha intenzionalmente lasciato aperto.

Domanda di handoff:

Esiste sufficiente significato governato per derivare la minima Base Analysis senza scegliere interpretazioni non supportate o importare dettagli di livello inferiore?

Se no, tornare al semantic owner nel document layer.

MR-0003 – BA boundary

Una futura BA derivata dal successor governato non deve richiedere una specifica **GovernedIdentity** come input preesistente della responsabilita' di determinazione. Se la BA la richiede, si attiva una semantic regression review: potrebbe essere un errore di derivazione, una perdita espressiva della BA o un problema documentale, ma non una nuova project truth.

16 Step 14 – BA / analysis feedback senza authority inversion

Un mismatch BA non dimostra automaticamente un difetto documentale. Le diagnosi minime sono:

```
documentation ambiguity
BA derivation error
missing governed fact
BA expressiveness problem
```

Il loop corretto e':

```
governed documentation
-> minimum justified BA
-> semantic / structural regression
-> diagnostic
-> correction candidate
-> governed review
-> updated documentation
-> rebuilt BA
```

17 Checklist compatta documento per documento

Step	Domande da non saltare
Authority	Quale baseline e' autorizzata? Sto usando recency come authority?
Framing	Il problema resta valido rimuovendo la soluzione corrente? Boundary chiaro?
MR	Una macro-responsabilita'? Significato stabile? Niente scelta tecnica o FR atomico?

Step	Domande da non saltare
Semantic sufficiency	Esistono letture materialmente diverse? Qual e' la smallest critical proposition? Evidenza AFFIRMED/DENIED/NOT SPECIFIED/CONFLICTING?
Decision	Quale material commitment restringe il MR? E' davvero posseduto da questo MR? Conseguenze materiali?
FR	Quale comportamento MUST? Risultato osservabile? Una coherent functional unit? Testabile senza inventare significato?
Requirement split	Le clausole formano una sola obbligazione coerente? Possono evolvere/essere assessed indipendentemente?
SR	Strengthening di un solo FR? Removal test? Niente duplicazione funzionale o realization leakage?
SecurityRequirement	Una sola security property? Failure mode identificabile? Niente generic "secure", cause o control prematuro?
Consumed service	Consumption o ownership? Se serve P, il service governa davvero P? NOT SPECIFIED resta NOT SPECIFIED?
Terminology	Stessa semantic identity, stesso governed term/binding? Marker temporanei rimossi dal final prose?
Propagation	La correzione upstream e' preservata nei child? Ci sono silent preconditions o semantic loss?
Promotion	Successor completo? Gap espliciti? Authority registry aggiornato?
BA handoff	Posso derivare la minimum BA senza inventare? Se la BA diverge, quale diagnosi e' plausibile?

18 Known open items – non chiudere per comodita'

OPEN / DEFERRED

La guida conserva esplicitamente i seguenti punti aperti o evidence-gated.

1. rappresentazione document-layer/L1 esatta del target di un consumed service/capability;
2. universal service-property contract;
3. automatic residual-obligation generation;
4. provenance/change-event model completo fra analysis e governed-document revisions;
5. general role-aware BA topology regression method;
6. integrated Base Analysis / BA6 closure;
7. necessita'/ridondanza finale dei current BA2 operators dopo full-corpus retest;
8. eventuale reopen della regular Decision layer solo davanti a concrete recurring counterexamples;
9. universal taxonomy of semantic patterns;
10. network-specific metamodel.

19 Evidence map e status degli esempi

Gli esempi non hanno tutti la stessa authority. La guida usa esplicitamente il loro status:

Forward checkpoint. methodology/DDTA_DOCUMENTATION_METHOD_BASELINE_R24_CHECKPOINT_R1.md – question set e status epistemici correnti.

FR authoring closure evidence. 03-functional-requirement/02-authoring-guidance/DDTA_AUTHORING_RULES_THROUGH_FR_R2.md – framing, MR, Decision, FR e service composition.

S1 SpecializedRequirement closure. CLOSED EVIDENCE – strengthening, removal test e parent dependence.

S1.5-A Requirement abstraction. CLOSED nel proprio scope – Requirement, normativeClause[1..*] e split rule.

S2 SecurityRequirement closure. CLOSED EVIDENCE – protectedSecurityProperty e failure-mode semantics.

MR-0003 R1. governed-corpora/facial-access/current/MR-0003_IDENTITY_VERIFICATION.md – SUPERSEDED regression evidence; usato per mostrare l’ambiguità pre-correction.

MR-0003 candidate R2. governed-corpora/facial-access/candidate-r2/MR-0003_IDENTITY_DETERMINATION.md – EXPERIMENTAL_NON_CANONICAL; usato come esempio di wording candidato corretto.

Candidate Decisions. governed-corpora/facial-access/candidate-r2/DECISIONS.md – EXPERIMENTAL_NON_CANONICAL; esempi D-3.1 e D-3.2.

Candidate FunctionalRequirement. governed-corpora/facial-access/candidate-r2/FUNCTIONAL_REQUIREMENTS.md – EXPERIMENTAL_NON_CANONICAL; esempio FR-3.2.1.

SecurityRequirements R1. governed-corpora/facial-access/current/SECURITY_REQUIREMENTS.md – SUPERSEDED regression evidence; esempi mechanism-neutral di confidentiality, integrity e authorized provenance.

20 Final acceptance rule for this guide

Una rappresentazione documentale e’ accettabile quando e’:

1. leggibile da autori e reviewer di progetto;
2. fedele al livello di astrazione governato;
3. semanticamente sufficiente per evitare letture materialmente divergenti dove il progetto ha già una risposta;
4. esplicitamente incompleta dove il progetto non ha ancora governato la risposta;
5. abbastanza testabile al livello FR/SR pertinente senza inventare meccanismi;
6. abbastanza stabile da poter evolvere la realization senza riscrivere responsabilita’ che non sono cambiate;
7. pronta per una Base Analysis minima che normalizza, non crea, il significato.

R24 DRAFT DISPOSITION

Questa R2 e’ una guida operativa derivata dal checkpoint documentale. Prima della promozione forward definitiva deve essere riletta contro il checkpoint, verificata sugli esempi Facial Access e poi usata per il successivo full documentation rewrite. Le regole R24 WORKING restano esplicitamente candidate finche’ ulteriori pressure test non ne giustificano la closure.